

UNIVERSIDAD AUTÓNOMA DE NUEVO LEÓN

Facultad de Ciencias Físico Matemáticas

Programa de Seguridad

PIA SGSI

NovaTech Solutions S.A. de C.V.

Datos de Identificación:

2169375 CARLOS GIOVANNI REYES MEDINA

1976909 SOFIA LIZBETH PEREZ MUÑIZ

21224550 FRANCISCO CRUZ ZAPATA

2116041 EMILIO GONZÁLES VARGAS

1. Documento Marco del SGSI

Sistema de Gestión de Seguridad de la Información

Documento Marco — Versión 1.0

Organización: NovaTech Solutions S.A. de C.V.

Clasificación: Uso Interno Restringido

Elaborado por: Comité de Seguridad de la Información

Revisado por: CISO | **Aprobado por:** Dirección General

1. Propósito y Contexto del Documento

El presente documento constituye el marco rector del Sistema de Gestión de Seguridad de la Información (SGSI) de NovaTech Solutions S.A. de C.V. Su propósito es establecer los fundamentos estratégicos, operativos y normativos que regirán la gestión de la seguridad de la información dentro de la organización.

Este instrumento fue elaborado como respuesta directa a los eventos de seguridad registrados por la empresa durante el período 2024-2025, incluyendo el acceso no autorizado a repositorios de código fuente, la fuga de información confidencial de clientes a través de correo electrónico y la interrupción de seis horas del sistema CRM corporativo. Dichos eventos evidenciaron la inexistencia de un marco de gestión formal y la necesidad urgente de institucionalizar la seguridad de la información como función estratégica.

El SGSI diseñado en este documento se alinea con los requisitos de la norma internacional ISO/IEC 27001:2022, aplica la metodología de evaluación de riesgos OCTAVE Allegro y cumple con las disposiciones de la Ley Federal de Protección de Datos Personales en Posesión de los Particulares (LFPDPPP), así como con sus reglamentos y lineamientos derivados.

2. Objetivos de Seguridad de la Información

Los objetivos de seguridad de NovaTech Solutions han sido definidos en coherencia con los objetivos estratégicos del negocio, los cuales incluyen posicionarse como proveedor tecnológico líder para PyMEs en México, desarrollar productos SaaS propios y proteger la información que sostiene toda la operación.

2.1 Objetivo General

Establecer, implementar, mantener y mejorar continuamente un Sistema de Gestión de Seguridad de la Información que proteja la confidencialidad, integridad y disponibilidad de los activos de información de NovaTech Solutions, minimizando el riesgo de incidentes que puedan afectar la continuidad del negocio, la confianza de los clientes y el cumplimiento de la legislación aplicable.

2.2 Objetivos Específicos

# Objetivo	Indicador de Cumplimiento	Responsable
O-01 Proteger la confidencialidad del código fuente y la propiedad intelectual de NovaTech mediante controles formales de acceso.	Cero accesos no autorizados a repositorios en 12 meses posteriores a la implementación.	CISO / Director de Desarrollo
O-02 Garantizar la integridad de la información de clientes y documentos contractuales gestionados por el área de AC y Admón.	100% de los flujos de información confidencial con controles de validación y registro de trazabilidad.	CISO / Propietarios de Activos
O-03 Asegurar la disponibilidad de los sistemas críticos (CRM, plataformas en producción, repositorios) con tiempos probados.	RTO $\leq$ 4 horas y RPO $\leq$ 2 horas para sistemas clasificados como críticos.	CISO / Infraestructura TI
O-04 Cumplir íntegramente con las obligaciones derivadas de la LFPDPPP respecto al tratamiento de datos personales.	100% de procesos con tratamiento de datos personales cubiertos por Aviso de Privacidad vigente.	CISO / Responsable Privacidad
O-05 Establecer un proceso formal de gestión y respuesta a incidentes de seguridad que garantice contención y análisis.	Tiempo de detección y reporte $\leq$ 24 horas para el 90% de los incidentes registrados.	CISO / Equipo CSIRT
O-06 Desarrollar y mantener un programa de capacitación y concientización en seguridad que reduzca el error humano.	Cobertura del 100% del personal en entrenamiento; reducción del 50% en incidentes atribuibles a error humano en el primer año.	CISO / Recursos Humanos
O-07 Implementar un proceso de mejora continua del SGSI mediante revisiones periódicas de la dirección y auditorías.	Ejecución de al menos una auditoría interna y una revisión por la dirección por año.	CISO / Dirección General

3. Alcance del SGSI

3.1 Definición del Alcance

El SGSI abarca la totalidad de las operaciones, activos de información, procesos y sistemas en la sede de Monterrey, Nuevo León, México.

- **Unidades incluidas:** Área de Desarrollo de Software, Área de Atención a Clientes, Área de Administración, Dirección General.
- **Activos tecnológicos:** Servidores en la nube, Repositorios Git, Sistema CRM, Bases de datos, Correo corporativo, Almacenamiento nube, Dispositivos de empleados.

- **Exclusiones:** Sistemas de terceros sin control operativo directo.

4. Aplicación de la Triada CIA a NovaTech Solutions

4.1 Confidencialidad

Activo	Requisito de Confidencialidad	Nivel
Código fuente (Git)	Solo desarrolladores asignados al proyecto pueden acceder	Alto
Datos de clientes	Acceso restringido a personal de Atención a Clientes con necesidad operativa	Alto
Datos de empleados	Acceso exclusivo para RRHH y Dirección	Alto
Credenciales de acceso	Almacenamiento en gestores con cifrado; no compartición	Crítico
Info financiera/ contratos	Acceso restringido a Administración y Dirección General	Alto

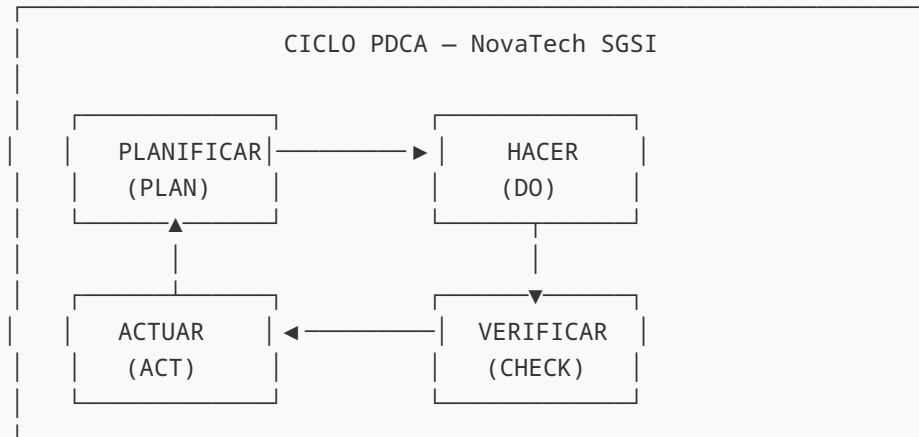
4.2 Integridad

Activo	Requisito de Integridad	Nivel
Código fuente	Sin alteraciones no autorizadas; control de versiones con firmas	Crítico
Bases de datos clientes	Datos precisos y consistentes; sin modificaciones no registradas	Alto
Información financiera	Registros contables precisos y auditables	Crítico
Logs de seguridad	Registros inmutables; sin alteración operativa	Alto

4.3 Disponibilidad

Activo	Requisito de Disponibilidad	RTO	RPO
Sistema CRM	99.5% de uptime en horario laboral	4 h	2 h
Repositorios Git / CI-CD	99.9% de uptime (activo crítico de producción)	2 h	1 h
Correo corporativo	99.0% de uptime	4 h	4 h
Plataformas web clientes	99.9% de uptime	1 h	30 min

5. Integración del Ciclo PDCA (Mejora Continua)



PLANIFICAR: Análisis del contexto, definición del alcance, inventario de activos, evaluación OCTAVE Allegro, selección de controles y políticas.

HACER: Implementación de controles MFA, monitoreo, capacitación, establecimiento del CSIRT, BCP/DRP y Aviso de Privacidad.

VERIFICAR: Auditorías internas, monitoreo continuo de KPIs y revisiones formales trimestrales.

ACTUAR: Revisión por la Dirección General, acciones correctivas y actualización de riesgos.

2. Contexto Organizacional y Estructura de Gobernanza

Versión 1.0 | Fecha: 30 de abril de 2026

1. Descripción General de la Organización

Razón Social: NovaTech Solutions S.A. de C.V.

Sector: Desarrollo de software y servicios digitales

Empleados: 120 | **Antigüedad:** 5 años

NovaTech Solutions es una empresa dedicada al desarrollo de plataformas digitales y ecosistemas de software para PyMEs en México. Ha experimentado un crecimiento acelerado que generó un desfase significativo entre la expansión operativa y la madurez de sus controles de seguridad.

1.1 Objetivos Estratégicos del Negocio

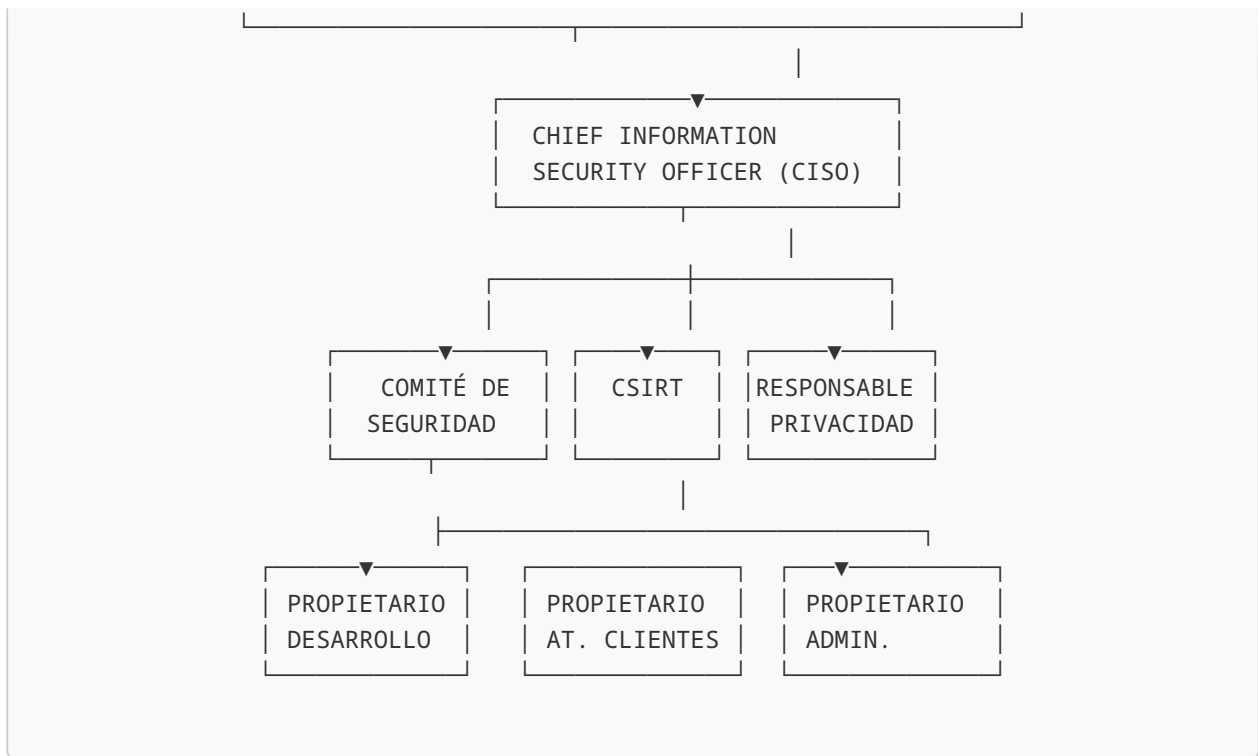
# Objetivo Estratégico	Implicación para el SGSI
E-01 Convertirse en uno de los proveedores tecnológicos más confiables para PyMEs.	La confiabilidad depende de la seguridad de la información. La reputación es un activo intangible crítico.
E-02 Desarrollar productos SaaS propios y comercializables.	El código fuente adquiere valor comercial directo. Su protección es estratégica.
E-03 Proteger formalmente la información crítica mediante la implementación de un SGSI.	El SGSI es un habilitador del negocio, no solo un requisito de cumplimiento.

2. Estructura Organizacional Actual

- **Área de Desarrollo de Software:** Núcleo operativo (Git, CI/CD).
- **Área de Atención a Clientes:** Soporte técnico, sistema CRM, base de datos de clientes.
- **Área de Administración:** Facturación, contratos, recursos humanos.

3. Estructura de Gobernanza de Seguridad

DIRECCIÓN GENERAL
(Patrocinador Ejecutivo del SGSI)



Se crea el rol de **CISO** para diseñar, implementar y mejorar el SGSI, con reporte a Dirección General. El **Comité de Seguridad** agrupa a los directores de área, el **CSIRT** atiende incidentes y el **Responsable de Privacidad** gestiona el cumplimiento de la LFPDPPP.

4. Matriz de Roles y Propietarios de Activos

Área	Rol	Responsable	Activos bajo custodia
Desarrollo	Propietario	Director Desarrollo	Git, CI/CD, código fuente
	Custodio	Líder Técnico	Git por proyecto
Atención Clientes	Propietario	Director AC	CRM, DB clientes, correos
	Custodio	Admin Sistemas	Sistema CRM
Administración	Propietario	Director Admvo.	Info financiera, RRHH
	Custodio	Resp. RRHH	Expedientes empleados (LFPDPPP)

3. Inventario y Gestión de Activos de Información

1. Criterios de Clasificación

Nivel	Etiqueta	Descripción
4	CRÍTICO	Daño severo e irreparable al negocio, pérdida masiva o consecuencias legales graves.
3	ALTO	Daño significativo a operaciones, recuperable pero costoso.
2	MEDIO	Interrupciones operativas moderadas.
1	BAJO	Impacto mínimo y fácilmente recuperable.

2. Inventario Formal de Activos de Información

Área de Desarrollo de Software

ID	Nombre del Activo	Criticidad	Observaciones
ACT-DS-001	Repositorios Git (código fuente)	4 — Crítico	Involucrado en Incidente #1. Requiere controles de acceso.
ACT-DS-002	Código fuente de productos SaaS	4 — Crítico	Propiedad intelectual estratégica futura.
ACT-DS-003	Servidores CI/CD	3 — Alto	Mala configuración interrumpe servicios críticos.
ACT-DS-005	Credenciales de acceso	4 — Crítico	Almacenamiento exclusivo en gestor de contraseñas.

Área de Atención a Clientes

ID	Nombre del Activo	Criticidad	Observaciones
ACT-AC-001	Sistema CRM Corporativo	4 — Crítico	Involucrado en Incidente #3. Prioridad para BCP/DRP.
ACT-AC-002	Base de Datos de Clientes	4 — Crítico	Protegidos por LFPDPPP.

ID	Nombre del Activo	Criticidad	Observaciones
ACT-AC-003	Correo Electrónico Corporativo	3 — Alto	Involucrado en Incidente #2. Requiere políticas DLP.

Área de Administración e Infraestructura

ID	Nombre del Activo	Criticidad	Observaciones
ACT-ADM-001	Base de Datos de Empleados	3 — Alto	Sujeto a LFPDPPP.
ACT-ADM-002	Información Financiera	4 — Crítico	Compromiso deriva en fraude o sanciones.
ACT-INF-001	Infraestructura Cloud (IaaS/PaaS)	4 — Crítico	Soporta todos los servicios digitales.
ACT-INF-003	Credenciales de Infraestructura	4 — Crítico	Proteger con MFA.

3. Resumen Ejecutivo del Inventario

Área	Total de Activos	Críticos (4)	Altos (3)	Medios (2)	Bajos (1)
Desarrollo de Software	7	3	3	1	0
Atención a Clientes	6	3	3	0	0
Administración	4	1	3	0	0
Infraestructura Compartida	5	3	2	0	0
TOTAL	22	10	11	1	0

Hallazgo Crítico: El 45% de los activos son Críticos y el 50% Altos. El 95% del inventario requiere controles de nivel alto/crítico.

4. Evaluación de Riesgos mediante Metodología OCTAVE Allegro

1. Metodología OCTAVE Allegro

La metodología se centra en activos críticos. Criterios de impacto (pesos): Reputación (5), Legal/LFPDPPP (5), Financiero (4), Operacional (4), Seguridad (3). Escala de Probabilidad: 1 a 3. Escala de Impacto: 1 a 3. Puntaje Máximo: 162.

2. Evaluación de los 3 Incidentes Históricos

● RIESGO-001: Acceso No Autorizado a Repositorio Git

"Un acceso desde IP desconocida en la madrugada por sesión abierta en equipo de cliente."

- **Activo:** Repositorios Git (ACT-DS-001).
- **Probabilidad:** Alta (3) | **Impacto Ponderado:** 54
- **Puntaje de Riesgo:** 162 / 162 (CRÍTICO)
- **Decisión:** Mitigar. Habilitar MFA, revocar credenciales, política de cierre de sesión y monitoreo.

● RIESGO-002: Fuga de Información de Clientes por Correo

"Reenvío por error de conversación con datos técnicos a dirección equivocada."

- **Activo:** Base de Datos Clientes / Correo (ACT-AC-002, ACT-AC-003).
- **Probabilidad:** Alta (3) | **Impacto Ponderado:** 51
- **Puntaje de Riesgo:** 153 / 162 (CRÍTICO)
- **Decisión:** Mitigar. Implementar DLP, segmentar CRM, emitir Aviso de Privacidad y capacitaciones LFPDPPP.

● RIESGO-003: Interrupción del CRM por Mala Configuración

"El CRM no respondió por 6 horas un viernes debido a una mala actualización."

- **Activo:** Sistema CRM / Infraestructura Cloud (ACT-AC-001).
- **Probabilidad:** Alta (3) | **Impacto Ponderado:** 51
- **Puntaje de Riesgo:** 153 / 162 (ALTO-CRÍTICO)
- **Decisión:** Mitigar. Establecer Change Management, verificar respaldos, crear ambiente staging y DRP.

5. Políticas de Seguridad de la Información

POLÍTICA PSI-01: Política General del SGSI

Define los principios rectores de Confidencialidad, Integridad y Disponibilidad. Todo empleado debe reportar inmediatamente incidentes de seguridad y cumplir la LFPDPPP. Se prioriza la mitigación del error humano mediante controles tecnológicos.

POLÍTICA PSI-02: Política de Control de Accesos

- **Mínimo Privilegio:** Acceso otorgado por proyecto, no por rol genérico.
- **Ciclo de Vida:** Alta aprobada formalmente. Modificaciones reportadas en 24h. Baja de accesos en máximo 4 horas tras la terminación de relación laboral.
- **Autenticación (MFA):** Obligatoria para Git, CRM, Nube, Correo y Finanzas. Contraseñas de min. 14 caracteres con gestor corporativo. Prohibido compartir.
- **Protección Git:** Prohibidas clonaciones en BYOD no autorizados o mantener sesiones activas fuera de la empresa.

POLÍTICA PSI-03: Política de Uso Aceptable

- **Uso del Correo:** Verificación manual del destinatario obligatoria antes de enviar info. confidencial. Cifrado obligatorio para bases de datos. Etiquetado [CONFIDENCIAL].
- **Equipos y Dispositivos:** Bloqueo automático a los 5 minutos. Prohibido uso de nubes personales (Google Drive personal, Dropbox).
- **Repositorios de Código:** Propiedad de NovaTech. Prohibido almacenar tokens o contraseñas en texto claro (hardcoding) dentro del código.

POLÍTICA PSI-04: Gestión de Incidentes de Seguridad

Obligación universal de reporte (canal: csirt@novatech.com.mx). Prohibido modificar evidencias. Los incidentes se clasifican en P1 (1h), P2 (4h), P3 (8h), P4 (24h). El no reportar un incidente constituye falta grave que puede derivar en despido.

6. Catálogo de Controles de Seguridad

1. Marco de Defensa en Profundidad

Capa 7: Personas y Procesos (Capacitación, políticas)
Capa 6: Controles Organizacionales (Gestión accesos)
Capa 5: Aplicaciones y Datos (MFA, DLP, Cifrado)
Capa 4: Endpoints / Dispositivos (Antivirus, bloqueo)
Capa 3: Red y Perímetro (VPN, Segmentación)
Capa 2: Infraestructura Nube (IAM, backups)
Capa 1: Física (Acceso a instalaciones)

2. Controles Preventivos, Detectivos y Correctivos

Tipo	ID	Control	Descripción
Preventivos	CP-01	MFA Obligatoria	En sistemas críticos (Git, CRM, Nube).
	CP-04	Mínimo Privilegio Git	Accesos por proyecto y protección de ramas.
	CP-06	Escaneo de secretos	Bloqueo automático de credenciales hardcodeadas.
	CP-13	DLP en Correo	Prevención de envío de info confidencial.
	CP-15	Change Management	Gestión formal de cambios para evitar interrupciones.
Detectivos	CD-01	Monitoreo Repositorios	Alertas de IPs y horarios anómalos.
	CD-02	Monitoreo CRM	Uptime Robot/Datadog para caídas.
	CD-06	Phishing Simulado	Simulacros semestrales a todo el personal.
Correctivos	CC-01	Plan CSIRT	Procedimiento formal documentado de respuesta.
	CC-03	Recuperación Respaldos	Procedimiento probado de restauración.
	CC-07	Notificación LFPDPPP	Proceso formal para notificar brechas al INAI/Titulares.

7. Plan de Continuidad del Negocio (BCP) y Recuperación (DRP)

1. Análisis de Impacto al Negocio (BIA)

Sistema	RTO (Tiempo)	RPO (Datos)
Plataformas web (clientes)	1 hora	30 minutos
Repositorios Git / CI-CD	2 horas	1 hora
Sistema CRM Corporativo	4 horas	2 horas

2. Plan de Continuidad (BCP) por Área

- **Desarrollo (Caída Git):** Uso de clones locales; activación de mirror secundario. Capacidad ~60%.
- **Atención a Clientes (Caída CRM):** Uso de directorio Excel cifrado exportado semanalmente. Registro manual de tickets; captura posterior en <4h. Capacidad ~40%.

3. Escenarios de Recuperación (DRP)

Escenario 1: Caída CRM por Actualización (P2)

Detección (0-30m) -> Diagnóstico (30-90m) -> Rollback de configuración o restauración de respaldo temporal si hay pérdida de datos. Lección: Recuperación debe ser $\leq 4h$.

Escenario 2: Ataque Ransomware (P1)

Aislamiento inmediato de red -> Preservación de evidencias -> NO pagar rescate sin análisis legal -> Levantar infraestructura limpia desde cero -> Restaurar desde backup limpio -> Aplicar hardening.

Escenario 3: Pérdida Definitiva de Datos

Si fallan backups: Detener escritura, recuperación manual mediante correos y logs. Notificación obligatoria bajo LFPDPPP.

8. Procedimiento Formal de Respuesta a Incidentes (CSIRT)

El CISO (Coordinador del CSIRT) tiene autoridad inmediata para aislar redes y revocar accesos. Basado en NIST SP 800-61 Rev. 2.

Fases del Ciclo de Respuesta

1. **Preparación:** Herramientas offline, directorio de emergencia, laptop limpia.
2. **Detección y Reporte:** Tiempos de reporte al CISO (P1: 30 min, P2: 1h). Uso del Formulario FRI-001.
3. **Análisis:** Revisión de logs y confirmación de impacto CIA y LFPDPPP.
4. **Contención:** Detener daño activo. *Reglas de oro: no modificar estado, crear imagen forense, mantener cadena de custodia.*
5. **Erradicación y Recuperación:** Eliminar vector, limpiar sistemas y restaurar operaciones desde respaldos.
6. **Lecciones Aprendidas:** Reunión y elaboración del Informe Post-Incidente (IPI) para P1/P2 en 10 días, actualizando el análisis de riesgos.

9. Capacitación y Concientización en Seguridad

Diseñado para reducir el error humano (causa de los 3 incidentes) en un 50%. Organizado en 4 perfiles: A (Todos), B (Desarrollo), C (Atención Clientes), D (Líderes).

Estructura del Programa (Q1-Q4)

- **Q1 Fundamentos:** Inducción al SGSI y Políticas. Simulacro de Phishing #1 (Diagnóstico, meta <40% clics).
- **Q2 Profundización Técnica:** Taller Ingeniería Social y MFA. Desarrollo Seguro OWASP Top 10 y Gestión de Secretos. Manejo Seguro de Datos de Clientes y LFPDPPP (Reglas de oro del CRM).
- **Q3 Práctica:** Simulacro Tabletop de respuesta a incidentes a las 2:47 AM para el CSIRT. Simulacro de Phishing #2 (Spear Phishing, meta <10%).
- **Q4 Evaluación:** Actualización Normativa. Evaluación anual en línea (mínimo 80%). Revisión del programa por la Dirección.

Onboarding de Seguridad

Todo empleado debe completar la inducción (3h 20m), configurar MFA/Gestor y firmar Acuerdos en los primeros 5 días, **ANTES** de recibir acceso a producción.

10. Métricas, Indicadores Clave y Auditoría Interna

1. Metodología de Semáforo y KSIs

ID	Indicador (KSI)	Meta	Umbral ROJO
KSI-02	Incidentes P1 y P2	0 P1 / Máx 2 P2	≥ 1 incidente P1
KSI-03	MTTD (Tiempo Detección)	≤ 4 horas	> 8 horas
KSI-07	Cobertura MFA en sistemas críticos	100%	< 100%
KSI-12	Cobertura parches críticos	100% en ≤ 24h	< 100% o > 24h
KSI-16	Disponibilidad Sistema CRM	≥ 99.5%	< 99.0%
KSI-22	Tasa de clics phishing simulado	≤ 10%	> 20%
KSI-26	Solicitudes ARCO atendidas	100% en plazo (20 días)	< 100%

2. Programa de Auditoría Interna (ISO 27001)

Calendario: Accesos (Trimestral), Vulnerabilidades (Mensual), Repositorios Git (Trimestral), Incidentes (Trimestral), Capacitación (Semestral), Auditoría Integral ISO 27001 (Anual - Septiembre).

Clasificación de Hallazgos: No Conformidad Mayor (riesgo legal/sistemático), No Conformidad Menor (fallo puntual), Observación (mejora).

11. Análisis de Cumplimiento Normativo (LFPDPPP e ISO 27001)

1. Obligaciones LFPDPPP

Obligación	Estado / Acción Requerida
Principio de Licitud (Consentimiento)	EN PROCESO . Cláusulas en nuevos contratos.
Aviso de Privacidad	CRÍTICO (30 DÍAS) . Requiere versiones web, clientes y empleados con finalidades, transferencias y medios ARCO.
Medidas de Seguridad	EN PROCESO . Falló en Incidente #2. Implementando DLP y políticas.
Derechos ARCO	Plazo legal: 20 días hábiles. Canal oficial: arco@novatech.com.mx
Notificación de Vulneraciones	Notificar a INAI y titulares ante pérdida o robo de datos.

Sanciones: El incumplimiento (como tratar datos sin consentimiento o no notificar vulneraciones) conlleva multas del INAI de hasta 320,000 días de salario mínimo (más de \$89 millones MXN a 2026).

2. Cumplimiento ISO/IEC 27001:2022 (SoA)

De los 93 controles del Anexo A, NovaTech tiene un avance de: **42 Implementados (45%)**, **31 En Proceso (33%)**, y **20 Pendientes/NA (22%)**.

-  Implementados: MFA, Políticas, BCP, Gestión de Incidentes, Capacitación.
-  En Proceso: IAM, DLP, Change Management, Auditoría.

3. Hoja de Ruta (Roadmap)

- **0-30 Días (CRÍTICA):** Aviso Privacidad, Designar Resp. Privacidad, Canal ARCO, MFA sistemas críticos, Gestor de contraseñas, Respaldos automáticos.
- **31-90 Días (ALTA):** DLP en correo, Segmentar CRM, Change Management, Contratos de Procesamiento de Datos (DPA) para proveedores Cloud.
- **91-180 Días (MEDIA):** SIEM (gestión de logs), Hardening de Infraestructura Cloud, Auditoría Integral ISO 27001.

Declaración Final de Compromiso

NovaTech Solutions reconoce que el cumplimiento normativo es un proceso continuo. La Dirección General asume el compromiso de mantener el SGSI en un ciclo de mejora continua (PDCA).